

YARA Cheat Sheet

YARA is used to identify and classify malware by matching patterns — text, byte sequences, or hashes — found in files or memory.

Rule Structure

```
rule Suspicious_PE_With_C2_Domain
{
  meta:
    author = "Kerry"
    description = "Flags PE files referencing a known bad domain"
    date = "2026-07-25"

  strings:
    $mz = { 4D 5A }
    $domain = "malicious-c2.com" nocase
    $ps_cmd = /powershell\s+-enc\s+[A-Za-z0-9+\./=]{20,}/

  condition:
    $mz at 0 and ($domain or $ps_cmd)
}
```

String Types

Type	Syntax	Example
Text string	"..."	\$a = "cmd.exe /c"
Hex string	{ }	\$b = { 4D 5A 90 00 }
Regex	/ /	\$c = /https?:\\/[a-z]+\./com/

String Modifiers

Modifier	What It Does
nocase	Case-insensitive match
wide	Matches UTF-16 encoded strings
ascii	Matches ASCII strings (default)
fullword	Matches only whole words, not substrings

base64	Matches the string in its base64-encoded form
xor	Matches the string against all single-byte XOR-encoded variants

Condition Possibilities

Matching Logic

Condition	What It Does
\$a	True if string \$a matches anywhere in the file
\$a and \$b	True only if both strings match
\$a or \$b	True if either string matches
not \$a	True if \$a does NOT match
any of them	True if any defined string matches
all of them	True if all defined strings match
1 of (\$a, \$b, \$c)	True if at least one of the listed strings matches
2 of (\$a, \$b, \$c)	True if at least two of the listed strings match
all of (\$a*)	True if all strings whose name starts with a match

Positional Conditions

Condition	What It Does
\$a at 0	True if \$a matches at file offset 0
\$a in (0..100)	True if \$a matches somewhere within the first 100 bytes
#a > 3	True if string \$a appears more than 3 times
@a[1] == 100	True if the first occurrence of \$a is at offset 100

File Property Conditions

--	--

Condition	What It Does
<code>filesize < 500KB</code>	True if the file is under 500KB
<code>filesize > 1MB</code>	True if the file is over 1MB
<code>uint16(0) == 0x5A4D</code>	Checks raw bytes at an offset — here, the MZ header of a PE file
<code>uint32(0) == 0x464C457F</code>	Checks for the ELF header (Linux executables)

Combining Everything

```
condition:
    uint16(0) == 0x5A4D and
    filesize < 2MB and
    2 of ($domain, $ps_cmd, $mz) and
    not $known_good_signature
```

Notes

- Conditions are evaluated as boolean logic, so any combination of `and`, `or`, `not`, and counting operators (`1 of`, `2 of`, `#a`) can be chained together.
- Checking `uint16(0)` or `uint32(0)` against known file header magic bytes (like `0x5A4D` for PE, `0x464C457F` for ELF) is a fast way to scope a rule to a specific file type before running heavier string checks.
- Combining a file-type check, a size constraint, and a minimum count of suspicious strings (`2 of ( ... )`) is a common pattern for reducing false positives compared to matching on a single string alone.